

PROPRIETARY // INTERNAL GOVERNANCE SYSTEM

AI OPERATIONS PLAYBOOK

The ITKeepers **KEEP Framework** for safe, useful and accountable AI across support, cloud, security, networking, automation and digital work.

AI belongs in the stack.
Accountability stays with people.

One operating standard for AI

AI should make ITKeepers faster without making client environments less controlled.

"Your IT person is a team."

That same principle applies to AI. A model may assist the team, but it does not become the owner of a ticket, a client decision, a production change or a security outcome.

This playbook is designed for ITKeepers only.

It assumes an MSP environment where engineers move between client tenants, endpoints, networks, security tools and business systems.

What this protects

- Client confidentiality across tenants
- Engineer accountability and professional judgment
- Production systems from unsafe automation
- ITKeepers' reputation and evidence trail

What this enables

- Safer use of copilots and LLMs
- Faster drafting, analysis and troubleshooting
- Controlled scripting and automation
- A repeatable AI governance service for clients

Status: draft governance framework. Management, legal/HR and security review should occur before this becomes enforceable policy. It is not legal advice.

Five rules that do not move

Everything else in this playbook is an implementation of these rules.

01

People own outcomes.

AI can assist. A named person remains accountable for what is sent, changed, approved or acted on.

02

Tools earn access.

No AI tool gets client data, tenant access or API permissions merely because it is useful.

03

Data follows boundaries.

Client A never becomes context for Client B. Minimum necessary context is the default.

04

Automation has brakes.

Anything that can change production must have scope limits, review, logging and a way to stop or reverse it.

05

Important work leaves a trace.

Higher-risk AI use must be reconstructible: tool, data class, reviewer, decision, action and result.

Know. Evaluate. Engineer. Protect.

A compact decision system engineers can apply before using AI.



K // Know the context

Classify the data. Separate tenants. Reduce the prompt to what is actually needed.

E // Evaluate the use

Check the AI tool registry and determine how much authority the AI will have.

E // Engineer the result

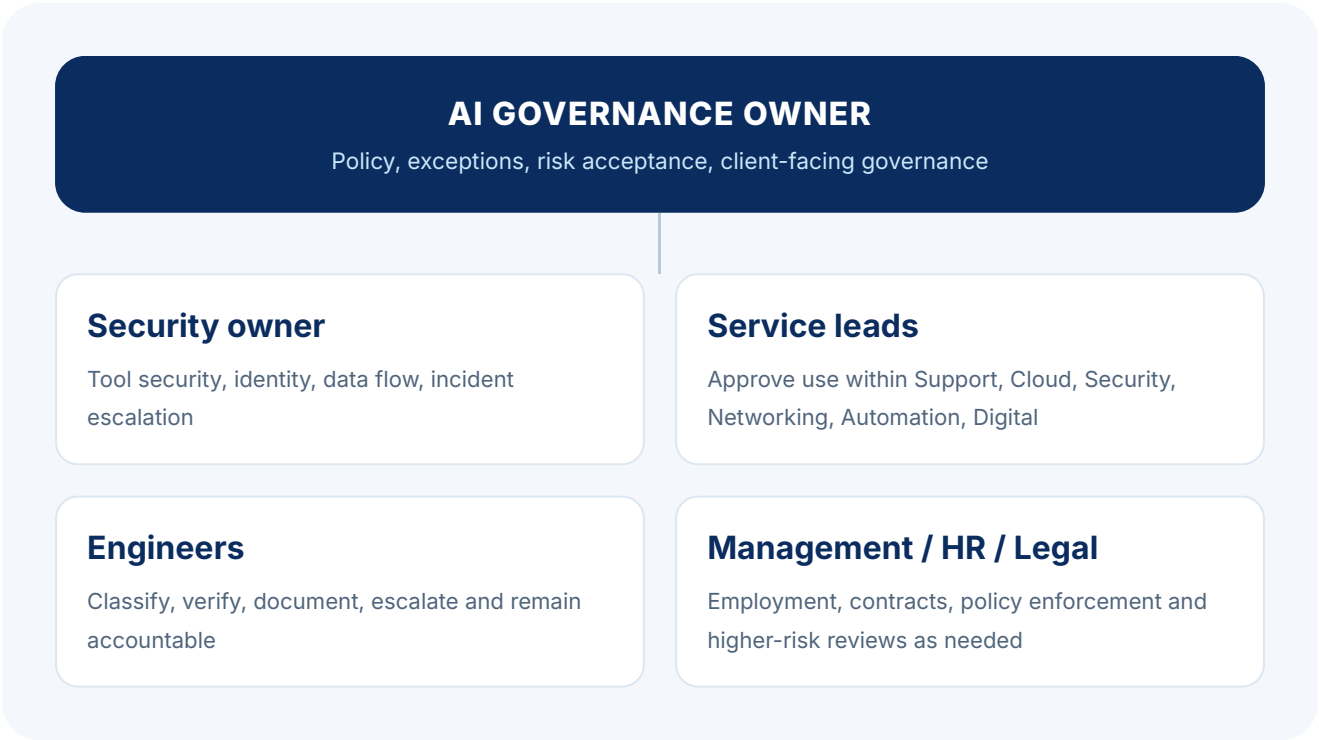
Human review is proportional to impact. Production work gets technical validation.

P // Protect + prove

Apply identity, endpoint and logging controls. Preserve evidence for higher-risk use.

A small board, clear owners

Governance should be lightweight enough to use and strong enough to stop unsafe adoption.



Approve new AI tool	Governance owner + Security	Approve production AI action	Service lead / change owner
Approve client-sensitive AI use	Security + service owner; client approval where contractually required	Report AI incident	Any employee immediately

Rule: no single employee can self-approve a new AI tool and simultaneously grant it sensitive data or production authority.

Every AI tool gets a profile

The approved-tool list is a control surface, not a software popularity list.



AI TOOL PROFILE

One record per approved service, model, agent or integration.

Identity

SSO? MFA? role control? managed account?

Data treatment

Retention, training use, deletion, residency, sub-processors

Capability

Read, generate, recommend, execute, autonomous

Connectivity

APIs, M365, ticketing, code, browser, endpoint access

- Business purpose is documented
- Owner and renewal date are assigned
- Allowed data classes are explicit
- Allowed service areas are explicit
- Audit/logging availability is known
- Vendor security and contract posture reviewed
- Offboarding / token revocation path tested
- Default deny for unreviewed connectors or plugins

Shadow AI

Unapproved personal/free accounts must not be used for official client work or sensitive company data.

TOOL RULE

Useful is not the same as approved.

Classify before you prompt

MSP risk starts with knowing whose data you are holding and how sensitive it is.

D0

Public

Public documentation, vendor KBs,
public website copy, generic examples.

Broadest AI use

D1

ITKeepers Internal

Internal procedures, non-sensitive notes,
draft SOPs, generic meeting notes.

Approved business AI only

D2

Client Confidential

Tickets, screenshots, configs, tenant
names, diagrams, logs, IPs, emails, asset
details.

**Approved tool + minimum necessary
context**

D3

**Restricted /
Regulated**

PII, HR, legal, finance, health, contract-
sensitive or regulated information.

Explicit higher-risk approval

D4

Secrets

Passwords, private keys, recovery
codes, API secrets, tokens and
equivalent credentials.

**Never paste into general-purpose AI
prompts**

Risk rises when AI can act

Data sensitivity matters. So does what the AI is allowed to do.



The default ceiling for general-purpose AI is A2.

A3 and A4 require explicit engineering controls, scoped permissions, evidence and rollback.

Data × authority = control level

Use the stricter requirement whenever two rules conflict.

Data / Authority	A0 Think	A1 Draft	A2 Recommend	A3 Execute	A4 Autopilot
D0 Public	Standard	Standard	Review	Controlled	Controlled
D1 Internal	Approved tool	Approved tool	Human validation	Change control	Formal approval
D2 Client Confidential	Approved profile	Sanitize + review	Qualified reviewer	Change + logging	Exception only
D3 Restricted	Explicit approval	Explicit approval	Formal assessment	Normally prohibited	Prohibited
D4 Secrets	Do not prompt	Do not prompt	Do not prompt	Dedicated secret-safe integration only	Prohibited by default

Standard
Review
Controlled
Stop / exception

Escalate when uncertain. Classify to the higher tier until a service lead or security owner confirms otherwise.

Support

AI can accelerate troubleshooting, documentation and communication - without turning tickets into training data.

SUPPORT

Fast answers. Clean context.

GOOD

- Summarize sanitized technical notes
- Rewrite a client update after facts are verified
- Explain public error codes and vendor documentation
- Draft KB steps from known-good internal procedures

REVIEW

- Ticket text containing names or business context
- Screenshots from remote sessions
- AI-generated root-cause hypotheses
- Client-facing troubleshooting instructions

NEVER

- Paste passwords, tokens or MFA codes
- Upload full unredacted ticket exports to personal AI
- Let AI close a serious incident without engineer validation
- Mix examples or data between client tenants

Ticket → Sanitize → AI assist → Engineer verify → Client / action

Ticket rule: the engineer owns the diagnosis and the client communication. AI output is working material, not evidence by itself.

Cloud

Microsoft 365, Entra, SharePoint and cloud copilots can see more than a normal chatbot. Permissions matter before prompts do.

CLOUD**Permission hygiene is AI hygiene.****Before enabling tenant-connected AI**

- Review SharePoint and Teams oversharing
- Confirm identity and Conditional Access controls
- Validate who can search which repositories
- Document tenant-specific data boundaries
- Review plugin / connector permissions separately

Engineer rules

- Do not assume retrieved documents are current
- Confirm source file, owner and version before action
- Treat generated admin steps as untrusted until validated
- Do not grant broad Graph/API scopes for convenience
- Record production changes in the normal ticket/change process

IDENTITY

PERMISSIONS

DATA

AI

HUMAN REVIEW

Cloud rule: AI inherits the consequences of bad permissions. Fix access first; then expand AI capability.

Security

Use AI to accelerate analysis, not to lower the standard for evidence or incident handling.

SECURITY

Assist the analyst. Do not replace the analyst.

Allowed patterns

- Summarize approved alert data
- Explain known indicators using public threat intelligence
- Draft detection logic for review
- Cluster similar events for analyst triage
- Create post-incident documentation after facts are established

Hard controls

- No secret material in general-purpose prompts
- No autonomous containment without pre-approved runbook
- No AI-only declaration that an incident is resolved
- No fabricated attribution or certainty
- Preserve original logs and evidence separately from AI summaries

EVIDENCE CHAIN

Original telemetry



AI analysis



Analyst validation



Decision

Security rule: AI may help interpret evidence. It must never become the only copy of the evidence.

Networking

Configurations are compact, powerful and often client-identifying. Treat them as sensitive engineering artifacts.

NETWORKING**Read-only first. Change second.****SANITIZE**

- Hostnames and client naming conventions
- Public/private IP addressing where sensitive
- VPN peers, remote endpoints and topology
- SNMP strings, credentials and secrets
- Customer-specific ACL comments and descriptions

VALIDATE

- Vendor syntax and software version
- Interface / VLAN / route scope
- Blast radius of a firewall or routing change
- Dependencies and management-path safety
- Rollback commands before implementation

RECORD

- AI-generated recommendation
- Engineer review
- Approved final commands
- Backup/export of current state
- Result and rollback outcome

Never paste and pray.

AI-generated network commands must be validated against the actual vendor, version and live topology before use.

Automation

The highest-value AI use cases are also the ones most likely to create large blast radii.

AUTOMATION

Scale the guardrails before you scale the action.

1**Scope**

Define exactly which tenant, users, devices or objects can be touched.

2**Read-only**

Observe and report before enabling write actions whenever practical.

3**Test**

Lab, sandbox, pilot group or dry-run. Never first-run across the fleet.

4**Approve**

A named human reviews the final logic and the intended target set.

5**Rollback**

Know how to stop, reverse or restore before execution.

6**Log**

Capture who approved, what ran, where, when and what changed.

Automation rule: AI-generated PowerShell, Bash, Python or API workflows are untrusted code until reviewed and tested.

Digital

AI can help ship websites and content faster. Client brands, source code and publishing rights still need human ownership.

DIGITAL

Generate quickly. Publish deliberately.

Content & design

- Fact-check business claims before publication
- Use client-approved brand assets and permissions
- Do not create fake testimonials, staff, awards or metrics
- Review copyright / licensing implications for generated media
- Mark placeholder or illustrative content clearly

Code & hosting

- Do not expose environment secrets or deployment tokens
- Review generated dependencies and licenses
- Security-test forms, auth and data handling
- Treat generated code like third-party code
- Human review before production deployment

DIGITAL RULE

AI can draft the page. ITKeepers still owns what goes live.

Minimum necessary context

Before you paste, attach or connect anything, reduce the data.

BEFORE

ABC Trading - Tenant ID 5f...
Admin: jane@abc.com
Public IP: 185.x.x.x
Screenshot with user names
Full ticket conversation
API token: sk-...



AFTER

Client A - Microsoft 365 tenant
Role: Global Admin
IP: [redacted unless needed]
Screenshot cropped to error only
Relevant technical excerpt
No credentials or secrets

Names

Replace personal names with roles unless identity is essential.

Screenshots

Crop aggressively. Check tabs, taskbar, browser profile, notifications and background windows.

Logs

Use only the lines needed. Remove tokens, cookies, identifiers and irrelevant payloads.

Tickets

Summarize the technical problem instead of exporting the entire conversation.

Configs

Redact secrets and unrelated client-specific topology before analysis.

Files

Do not upload an entire document set when a small excerpt will answer the question.

Prompt rule: if the AI does not need a detail to solve the task, the AI should not receive it.

Five gates before execution

AI output becomes operational risk the moment an engineer intends to run it.

01

Understand

Engineer can explain what each meaningful command or code path does.

02

Constrain

Targets, permissions, loops and destructive operations are bounded.

03

Test

Use dry-run, lab, test tenant, single object or safe pilot where available.

04

Recover

Backup/export exists and rollback is documented before the change.

05

Record

Ticket/change record links the reviewed code, approver, target and result.



AI GENERATED // REVIEW REQUIRED

```
Get-TargetSet | ForEach-Object {  
    # STOP: verify scope before enabling write action  
    Invoke-Change -Target $_ -Confirm:$false  
}
```

Peer review recommended: bulk changes, cross-tenant tooling, security policy changes, identity changes, firewall changes, backup deletion, destructive commands and anything difficult to roll back.

If AI can act, it needs a brake

Autonomy is a systems-design problem, not a prompt-writing feature.

BOUNDARY

Permission brake

Dedicated least-privilege identity. No shared admin accounts. No unnecessary tenant-wide scope.

BOUNDARY

Data brake

Only approved data sources and client contexts. Retrieval stores separated where needed.

BOUNDARY

Action brake

Allowlist commands/actions. Deny destructive or high-impact operations by default.

BOUNDARY

Volume brake

Rate, count and target limits prevent one bad plan from becoming a fleet-wide event.

CONTROL

Human brake

Require approval at defined checkpoints before production-impacting actions.

CONTROL

Kill switch

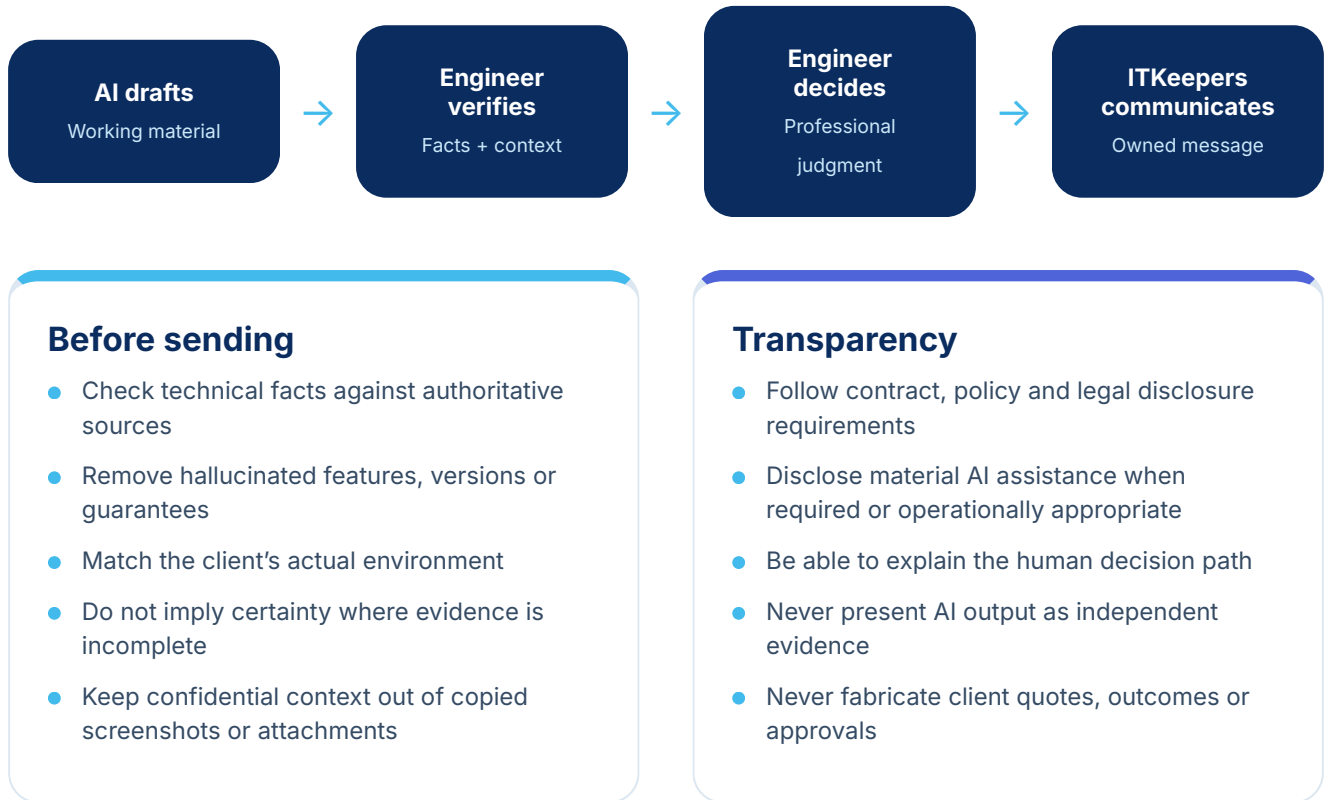
Immediate way to revoke token, disable identity, stop workflow or isolate integration.

A4 Autopilot is an exception.

It needs formal design review, monitoring, rollback, owner, expiry/review date and tested stop conditions.

AI never signs its own work

Anything that reaches a client carries ITKeepers' name, not the model's.



CLIENT RULE

The person who sends it owns it.

Treat AI failures like operational incidents

Move quickly, preserve evidence and stop further exposure or action.

AI-1

Policy drift

Unapproved tool or process used with no sensitive exposure and no production impact.

Document + correct + review

AI-2

Bad output escaped

Incorrect AI-generated advice, report, client communication or code reached operational use.

Contain + correct + assess impact

AI-3

Data exposure

Client-sensitive or restricted information entered into an unauthorized tool or context.

Immediate escalation + preserve evidence

AI-4

Production impact

AI-driven action causes outage, security impact, data loss, unauthorized change or material client harm.

Critical incident process + stop automation

STOP / CONTAIN → PRESERVE → ESCALATE → ASSESS → RECOVER → LEARN

Never hide an AI mistake. Failure to report can turn a small mistake into a cross-client, security or contractual incident.

Policy alone is not a control

Where supported, enforce the AI policy with the same layers ITKeepers already uses to manage identity, endpoints and security.

IDENTITY	Entra ID / SSO / MFA / Conditional Access	Approved accounts, strong authentication, controlled access.
ENDPOINT	Intune / application control	Managed devices, app restrictions, browser and endpoint posture.
APPLICATION	ThreatLocker / allowlisting where applicable	Prevent unapproved local AI applications or uncontrolled executables.
DATA	DLP / sensitivity controls where licensed	Reduce accidental copy/paste or upload of sensitive information.
NETWORK	DNS / web filtering / firewall	Limit known unapproved services where appropriate.
Licensing matters: controls differ by client and ITKeepers tenant. The approved-tool profile must state which controls are actually available, not merely desirable.		
and automation failures.		

Make risky AI use reconstructible

The goal is not to log every brainstorm. The goal is to preserve the evidence that matters.

AI CHANGE LEDGER	EXAMPLE FIELDS
Who	Engineer / approver / service owner
What	Tool + model/integration + workflow version
Context	Client, service area, ticket/change reference
Data	D0-D4 classification + sanitization performed
Authority	A0-A4 level + permissions granted
Control	Test, approval, rollback and monitoring evidence
Result	Output/action, validation result, exceptions or incident link

Review cadence

- Approved tools: quarterly or on material vendor change
- A4/autonomous workflows: defined review date and owner
- Policy: at least annually and after major incidents
- Client-specific exceptions: expire unless renewed

Do not over-log

- Avoid storing secrets inside AI audit records
- Respect client retention obligations
- Store evidence in approved ITKeepers systems
- Keep only what is necessary to prove safe operation

Teach the work people actually do

Generic AI awareness is not enough for an MSP. Training should look like a real ticket, real screenshot and real change window.

MODULE 01

Prompt safely

Data classes, redaction, screenshots, client separation, approved tools.

MODULE 02

Verify output

Sources, hallucinations, environment-specific checks, client communications.

MODULE 03

Change safely

Scripts, dry-run, least privilege, backups, rollback, peer review.

MODULE 04

Escalate early

Shadow AI, data exposure, wrong output, autonomous failures, evidence preservation.

ONBOARDING → ANNUAL REFRESH → TOOL / POLICY CHANGE → POST-INCIDENT LEARNING

Access can follow training. Higher-risk AI tools may be restricted until required training and acknowledgement are complete.

AI use / tool review

Use for new tools, integrations, high-impact workflows or client-sensitive use.

1. Purpose	What problem does this solve, and why is AI needed?
2. Tool	Provider, product/model, account type, owner.
3. Client context	Which clients or tenants could be involved?
4. Data class	D0 / D1 / D2 / D3 / D4 - highest level expected.
5. Authority	A0 / A1 / A2 / A3 / A4 - highest action capability.
6. Data handling	Retention, training use, deletion, residency, redaction.
7. Access	SSO, MFA, permissions, API scopes, connectors, service account.
8. Human control	Who reviews and approves? At which step?
9. Failure plan	Stop condition, rollback, backup, escalation and kill switch.
10. Evidence	Where are logs, approvals, tests and review date stored?

DECISION

☐ Approve
 ☐ Approve with controls
 ☐ Reject
 ☐ More evidence required

OWNER / DATE

Before using AI on client work

The 30-second version of the playbook.

DO

- Use an approved AI tool
- Know the client and data class
- Reduce context to the minimum necessary
- Verify facts, code and technical recommendations
- Use change control for production actions
- Record higher-risk use and approvals
- Escalate uncertainty early

DON'T

- Paste credentials, tokens or recovery codes
- Use personal/free AI for sensitive client work
- Upload unredacted ticket exports or screenshots
- Blindly run generated commands
- Let AI make final high-impact decisions
- Mix data between clients
- Hide an AI mistake or data exposure

STOP AND ESCALATE WHEN...

you cannot classify the data

the tool is not approved

the AI will change production

regulated / restricted data is involved

the blast radius is unclear

the output cannot be independently verified

REMEMBER

The AI can be fast. The engineer still has to be right.

AI belongs in the stack. Accountability stays with people.

Built around the ITKeepers operating model:

Support · Cloud · Security · Networking · Automation · Digital

K Know · **E** Evaluate · **E** Engineer · **P** Protect + Prove

YOUR IT PERSON IS A TEAM.

PROPRIETARY // INTERNAL USE